Investigating the Security of EV Charging Mobile Applications as an Attack Surface

KHALED SARIEDDINE and MOHAMMAD ALI SAYED, The Security Research Centre, Concordia University, Canada
SADEGH TORABI, Center for Secure Information Systems, George Mason University, USA
RIBAL ATALLAH, Hydro-Quebec Research Institute, Canada
CHADI ASSI, The Security Research Centre, Concordia University, Canada

The adoption rate of EVs has witnessed a significant increase in recent years driven by multiple factors, chief among which is the increased flexibility and ease of access to charging infrastructure. To improve user experience and increase system flexibility, mobile applications have been incorporated into the EV charging ecosystem. EV charging mobile applications allow consumers to remotely trigger actions on charging stations and use functionalities such as start/stop charging sessions, pay for usage, and locate charging stations, to name a few. In this article, we study the security posture of the EV charging ecosystem against a new type of remote that exploits vulnerabilities in the EV charging mobile applications as an attack surface. We leverage a combination of static and dynamic analysis techniques to analyze the security of widely used EV charging mobile applications. Our analysis was performed on 31 of the most widely used mobile applications including their interactions with various components such as cloud management systems. The attack scenarios that exploit these vulnerabilities were verified on a real-time co-simulation test bed. Our discoveries indicate the lack of user/vehicle verification and improper authorization for critical functions, which allow adversaries to remotely hijack charging sessions and launch attacks against the connected critical infrastructure. The attacks were demonstrated using the EVCS mobile applications showing the feasibility and the applicability of our attacks. Indeed, we discuss specific remote attack scenarios and their impact on EV users. More importantly, our analysis results demonstrate the feasibility of leveraging existing vulnerabilities across various EV charging mobile applications to perform wide-scale coordinated remote charging/discharging attacks against the connected critical infrastructure (e.g., power grid), with significant economical and operational implications. Finally, we propose countermeasures to secure the infrastructure and impede adversaries from performing reconnaissance and launching remote attacks using compromised accounts.

CCS Concepts: • **Security and privacy → Distributed systems security;**

Additional Key Words and Phrases: Electric vehicle charging, cyber-physical systems, security analysis, mobile application

This research was conducted and funded as part of the Concordia University/Hydro-Quebec/NSERC research collaboration project "Large-scale Integration of EVCSs into the Smart Grid: A Comprehensive Cyber-physical Study and Security Assessment." Grant reference: ALLRP 567144-21.

Authors' addresses: K. Sarieddine, M. A. Sayed, and C. Assi, The Security Research Centre, Concordia University, 1515 Saint-Catherine St W, Montreal, QC, H3G 1S6, Canada; emails: khaled.sarieddine@mail.concordia.ca, Mohammad.sayed@mail.concordia.ca, assi@encs.concordia.ca; S. Torabi, Center for Secure Information Systems, George Mason University, 10401 York River Rd, Fairfax, VA 22030, United States; email: storabi@gmu.edu; R. Atallah, Hydro-Quebec Research Institute, 1800 Bd Lionel-Boulet, Varennes, QC, J3X 1S1, Canada; email: atallah.ribal@hydroquebec.com.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
© 2023 Copyright held by the owner/author(s). Publication rights licensed to ACM.

2378-962X/2023/10-ART26 $15.00
https://doi.org/10.1145/3609508

ACM Reference format:
Khaled Sarieddine, Mohammad Ali Sayed, Sadegh Torabi, Ribal Atallah, and Chadi Assi. 2023. Investigating the Security of EV Charging Mobile Applications as an Attack Surface. *ACM Trans. Cyber-Phys. Syst.* 7, 4, Article 26 (October 2023), 28 pages.
https://doi.org/10.1145/3609508

1 INTRODUCTION

Climate change and increased greenhouse gas emissions are fueling society's embrace of a green technology mindset. Governments are diligently working on shifting the traditional transportation system to a smarter one by utilizing **Electric Vehicles (EVs)**. Many countries have already implemented policies to reach carbon neutrality, partly by adopting EVs, with an aim to reach 30% EV market share by 2030. For instance, China's plan to reach carbon neutrality resulted in a significant 141% increase in the deliveries of EVs in October 2021 [1]. Similarly, multiple federal/provincial governments in North America along with various European countries have set policies to increase EV adoption in the next decade while banning the sale of new gasoline-powered passenger cars in the near future [2, 3]. Consequently, there is a rapid deployment of **EV Charging Stations (EVCSs)** to match EV adoption. Furthermore, governments are actively investing in the EV charging infrastructure to address the lag of EVCSs with respect to the increasing demand caused by the shift toward EVs [4].

The leading automotive companies are investing in incorporating advanced technological features in EVs and the **Cyber-Physical System (CPS)** associated with them for remote management. The **cloud management system (CMS)** manages all operations and functionalities of the public EVCS. As a result of the need to commercialize the EV charging ecosystem and to drive the adoption of EV technologies, the EV charging mobile application established itself as a core component of the EV ecosystem [5]. Mobile applications are used by EV consumers to remotely control EVCSs and manage charging operations (e.g., start and stop charging sessions) through the CMS. They also provide various online functionalities such as checking availability and handling payments, to name a few. The importance of studying this component in a fine-grained manner lies in its ability to control the EVCS and its wide distribution among customers. The existence of multiple vendors, along with minimal efforts to standardize the development and deployment of EVCS components, has exposed the ecosystem and the interconnected critical infrastructure (e.g., power grid) to a wide range of remote attacks [6, 7]. Moreover, the massive adoption of EVs caused a compelling change in the transportation system and the power grid, not only increasing the load but also increasing the complexity of the ecosystem as a whole [8]. This adoption led to the rapid deployment of Internet-enabled EVCSs along with various supporting EV charging mobile applications. Moreover, the number of product and cross-product applications is increasing tremendously, where one mobile application might have access to more than one EVCS network (e.g., Flo, Blink, and EVgo), thus amplifying the impact by exposing more products and users simultaneously. It is worth highlighting that such extended remote functionalities provide adversaries with a new attack surface, which could be utilized to compromise the vulnerable mobile application and thus exploit the underlying EVCSs and their operation.

A number of studies focused on the security of the EV ecosystem by exploring the security of the firmware, the installed management systems, and the communication link [7, 9–12]. For instance, Nasr et al. [7] studied the security of the EVCS firmware and management systems and discovered 13 severe vulnerabilities. Furthermore, Antoun et al. [12] presented a detailed security analysis of the ecosystem while assuming a highly privileged attacker that can fake, intercept, inject, and modify messages. Alcaraz et al. [9] studied the security posture of the OCPP protocol, which is

the main protocol used to control EVCSs, and discovered its susceptibility to **Man-in-the-Middle (MITM)** attacks. Despite such efforts to explore the security of various components within the EV charging ecosystem, there is a lack of knowledge about the security posture of the existing EV charging mobile applications as an attacker entry point. Moreover, there is a lack of understanding about the extended attacker capabilities and attack implications when leveraging vulnerabilities across widely used mobile applications to perform large-scale coordinated attacks against various stakeholders and components within the EV charging ecosystem.

In this study, we focus on investigating the security posture of the EV charging mobile applications as an attack surface on the EV charging ecosystem and the underlying infrastructure. We are the first to systematically analyze the most widely used EV charging mobile applications that are utilized to manage EVCSs across various geographical locations. We focus on identifying design flaws in the interaction between the different components as it requires a deeper understanding of the ecosystem and advanced threat modeling. We utilize reverse engineering and code analysis techniques to get insight into the functionalities instilled in the EV charging mobile applications, along with the security measures implemented by these applications (e.g., bot detection libraries). Consequently, guided by the static analysis, we perform dynamic functionality analysis to test the interactions of these applications with other components while identifying their main implemented EV charging-related functionalities that can be triggered remotely (e.g., remote start and stop). Furthermore, we analyze the traffic exchanged between the EV charging mobile application and the CMS to understand their interactions. We also examined the exchanged information by breaking SSL using MITM monitoring to unravel encrypted interactions. Additionally, we utilize a deep understanding of the ecosystem and the available literature to complement our analysis of the EVCS-Cloud communication [7, 9, 13, 14].

Our analysis of the exchanged traffic/interactions allowed us to infer state transitions between the mobile application and other entities in the EV charging ecosystem. We found that the analyzed mobile applications lack adequate EV ownership verification. Moreover, most applications implement improper authorization for initiating critical functions (e.g., start charging), which only binds users with EVCSs without binding/authenticating users to the EVs. This is closely related to the lack of adequate EV ownership, which allows insecure initiation of a critical function such as EV charging/discharging. Indeed, we found a lack of proper ownership checking and improper authorization for critical functions (start and stop charging). While such vulnerabilities demonstrate the insecurity of the EV charging ecosystem, they also highlight the immaturity of the deployed software components, which hinders the advancement to reach the goals set by the industry. Furthermore, 29 out of 31 studied mobile platforms are susceptible to remote charging session hijacking while enabling mass (dis)charging attacks. Additionally, our analysis illustrates that 19 of the vulnerable EV charging mobile application platforms can be exploited to perform large-scale oscillatory load attacks on the connected infrastructure through the unauthorized remote start/stop charging capabilities. Consequently, we study the feasibility of synchronized remote charging attacks and their impact on the underlying infrastructure by studying transmission losses and generation costs, along with overloading and transmission line tripping and power grid stability. Finally, we provide recommendations to prevent remote attacks utilizing the EV charging mobile application. To this end, we frame the main contributions of this work as follows:

- To the best of our knowledge, we are the first to study the security posture of EV charging mobile applications as an attack surface against the power grid. We study the interactions of the different components and validate them on a real-time co-simulation test bed. Our findings demonstrate the insecurity of such mobile applications while highlighting design and implementation weaknesses that can be exploited to perform unauthorized operations on the underlying EVCSs.

- We leverage static and dynamic analysis techniques to analyze the implementation of EV charging mobile applications and their interactions with various components within the ecosystem. We utilize Finite State Machines to provide an abstract representation and model the interactions of the mobile applications with the cloud management system and the EVCS counterparts. Our analysis indicates several vulnerable interactions due to unverified user/vehicle ownership and improper authorization for critical functions. We demonstrate such attacks by showing successful proof-of-concept attack scenarios that exploit the design flaws we discovered.
- Given the feasibility of the identified vulnerabilities across widely used EV charging mobile applications, we investigate the implications of wide-scale remote attack scenarios by constructing synchronized botnet attacks that utilize the mobile applications as a recon to perform various unauthorized charging operations including large-scale voltage/frequency instability attacks on the power grid. We discuss practical attack implications against the stakeholders, precisely, and the connected power grid infrastructure. Finally, we propose design/implementation countermeasures to mitigate such attacks in the future.

The remainder of this article is organized as follows. In Section 2, we present background information and basic concepts related to the EV ecosystem. In Section 3, we discuss the analysis methodology. In Section 4, we discuss our findings in terms of identified interactions and vulnerabilities, along with attack feasibility. We discuss detailed attack implications against various stakeholders in Section 5. In Section 6, we discuss a mitigation framework along with security measures that will help defend against such exploitation before concluding the article in Section 7.

2 SYSTEM MODEL, RELATED WORKS, AND THREAT MODEL

The EV charging ecosystem is a cyber-physical system, composed of interacting hardware and software components. In what follows, we provide details about these components and their interactions.

2.1 System Model

The EVCS ecosystem incorporates multiple entities that collaborate and interact to provide a vital service to customers (individuals and businesses). It is the main enabler for EVs, which have been spreading rapidly due to governmental policies that have driven their adoption. The EVCS ecosystem consists of a cyber and a physical layer, as shown in Figure 1.

2.1.1 Cyber Layer. The Cyber Layer is composed of multiple software components coupled with the hardware/physical counterpart. The mobile applications are publicly available and distributed through application stores (Google Play and Play Store). These applications are needed by users to control EVCSs remotely and view EVCSs' status through their communication with the CMS. The mobile applications could be either operator specific (manage EVCSs belonging to one operator) or multi-operator (manage EVCSs of multiple operators). The multi-operator mobile applications were introduced to simplify the charging process and enable EV roaming among different operators without the need for operator-specific subscriptions. Consequently, based on the above distinction, the operator-specific mobile application communicates with the operator's CMS, whereas the multi-operator mobile application communicates with its owner's backend, which in turn forwards the requests to the respective operator's CMS using the **Open Charge Point Interface (OCPI)** [13].

The CMS plays an equally important role in the ecosystem since it provides API endpoints for the mobile application to communicate with the EVCS. Each operator has their own CMS that is responsible for reservation, scheduling, payments, management, monitoring, and so forth. The

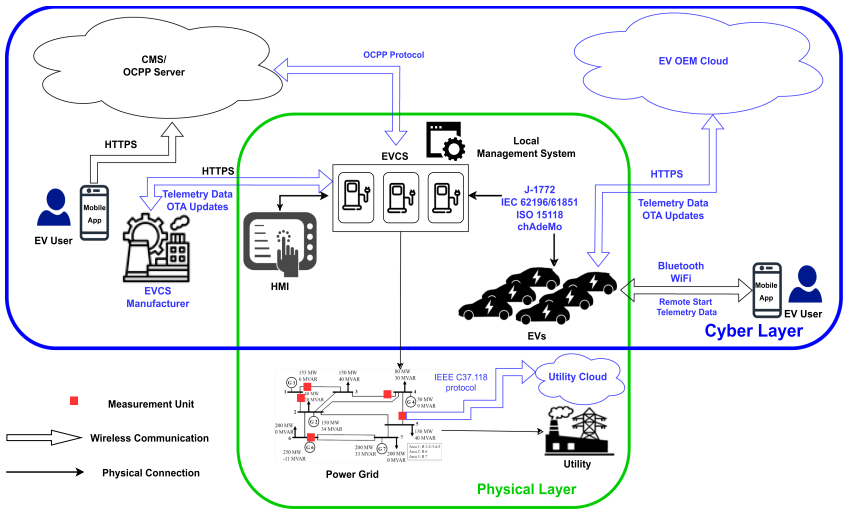


Fig. 1. Overview of the EV charging ecosystem and its interactions.

CMS is the most computationally capable component and it is considered the main driver of the ecosystem. However, to control EVCSs, the CMS communicates with the EVCS using the **Open Charge Point Protocol (OCPP)**.

The OCPP is the de facto standard that is utilized to manage EVCSs remotely. The OCPP defines two main roles, a lightweight client (EVCS) and a central server (CMS), which utilizes full-duplex communication over a TCP connection. The communication of the OCPP protocol is in the form of transaction functional blocks, where each entity requires a response to the initiated transaction. This standard is maintained and developed by an alliance of multiple companies working in the industry. Moreover, a connection is usually maintained between the EVCS and the original manufacturer, which helps in collecting logging information about the performance of the station. We have validated these interactions between the different components and the responsibility of each entity with our industrial partner Hydro-Quebec, a major North American utility.

Additionally, different cyber components exist but are not considered as a core component of the EVCS ecosystem and the connection is optional and does not necessarily always exist. For example, EVCSs maintain a connection with the **original equipment manufacturer (OEM)** to share telemetry data about the health of the device and its operational efficiency, which can be used later on to identify and enhance the product. Moreover, this connection is also used to push **over-the-air (OTA)** updates to ensure up-to-date software and the delivery of security patches in a timely manner. Moreover, the smart vehicles also are connected to their OEM cloud, which is used to share telemetry data and OTAs as well. Finally, there are mobile applications that are used by smart vehicle owners to start/stop the engine of a vehicle, Turn the air conditioning on, and so forth.

2.1.2 Physical Layer. The Physical Layer is represented by different entities. Namely, the EVCS hardware includes the human-machine interface that is used by the users to interact physically with the EVCS. After an EVCS is manufactured and bought by an operator, the manufacturer maintains a connection to push firmware updates remotely or can make the updates available online for the operator to manage the process. Moreover, the EVs have multiple hardware and software components including remotely accessible components such as an On-board Diagnostic Port and a CAN bus. The EV charging ecosystem was established to match the demand of EVs and their need

to charge. Two types of EVs are dependent on the EV charging ecosystem, which are the main foci when studying the security of the EV charging ecosystem: **Plug-in Hybrid EVs (PHEVs)** and Battery EVs [11, 15]. Other types of EVs such as Hybrid Electric Vehicles and Fuel Cell Electric Vehicles do not require external charging [16]. Consequently, EVs connect to the charging stations using various standards (SAE J-1772/J-2293/J-2847/J-2836, IEC 62196/61851, ISO/IEC 15118, and chAdeMO) [6, 7, 11], which are a part of the efforts to standardize communication in the EV charging ecosystem. Moreover, the IEEE 2030.5-2018 standard defines the application layer in the context of TCP/IP and facilitates the management of various utility functions related to end-user energy environments. These functions include demand response, load control, time-of-day pricing, distributed generation management, and electric vehicle integration. While this standard primarily focuses on the application protocol and its direct interaction, it also specifies the mechanisms for exchanging application messages, the specific content of those messages (including error messages), and the security features employed to safeguard the application messages. The application profile defined in this standard draws elements from various existing standards such as IEC 61968 and IEC 61850. Additionally, the **Combined Charging System (CCS)** is a communication protocol and charging standard used in EVs. It enables high-power charging by providing a single connector and communication interface for both AC and DC charging. It is widely adopted, and the CCS allows EVs to negotiate charging parameters and access a network of charging stations, making it a dominant standard in regions like Europe and North America. Moreover, ISO/IEC 15118 provides a standardized and secure interface for exchanging information during the charging process. The standard covers both wired and wireless communication interfaces, ensuring interoperability between different EVs and charging stations. It includes the Charging Communication Controller as a key component, which is responsible for handling communication between the EV and the charging infrastructure. ISO/IEC 15118 also introduces the concept of "Plug and Charge," allowing for automatic authentication and authorization of the charging session without the need for additional user interactions. Additionally, SAE J-1772, also known as the SAE Electric Vehicle Conductive Charge Coupler, is a standard that defines the physical and electrical interface between EVs and charging stations. It specifies the connector and signaling requirements for Level 1 and Level 2 charging, which are the common AC charging levels for EVs. The standard ensures interoperability and safety by providing a standardized connector design for charging infrastructure. It includes provisions for communication between the vehicle and the charging station, enabling features like power delivery control and safety interlocks. SAE J-1772 has been widely adopted in North America and is a crucial component of EV charging infrastructure in the region.

Moreover, there are several EVCS classifications. Level 1 chargers (slow chargers) are being replaced by Level 2 chargers, which are mostly used commercially as public EVCSs. Moreover, Level 3 chargers (providing a higher charging rate) are being introduced to improve the user experience and decrease charging times [6]. In this study, we focus on public EVCSs deployed by companies, governmental entities (e.g., Circuit Electric and ChargePoint), or private EVCSs that are made publicly available by the owner to earn extra income. It is worth highlighting that the EVCSs are also connected to the power grid (critical infrastructure) to draw the needed power for EVs to charge. Measurement units are distributed over the infrastructure and share information with the utility cloud. The utility utilizes this information to ensure visibility over the power grid.

2.2 Overview of EV Charging Mobile Application Platforms

To manage the ever-increasing number of EVCSs from different vendors, many companies have put in place a mobile application management platform for EV owners to monitor and control EVCSs. The mobile application is an indispensable component for the operation of the EV charging ecosystem. Consequently, we give an overview of the mobile application, which encompasses its

role and the communication protocols used when communicating with the different entities (CMS and EVCS). Mobile applications communicate with the CMS using **Hypertext Transfer Protocol Secure (HTTPS)**, which incorporates the **Secure Socket Layer (SSL)/Transport Layer Security (TLS)**, to secure and encrypt the HTTP communication and to preserve the privacy of users by protecting against on-path attacks. Various functionalities are instilled in the mobile application that provide users with an interface to remotely monitor and control EVCSs as illustrated in Figure 1. To name a few, a discovery service is provided by mobile applications to allow users to find nearby EVCSs. Furthermore, a control service is instilled to allow remote start and stop of charging sessions and schedule charging.

Various vendors provide mobile applications that allow remote monitoring/charging. To name a few, ChargePoint, a leading operator, has over 500,000 users. Similarly, ChargeHub is a popular mobile application that provides users with services to remotely control EVCSs. Indeed, the number of downloads of EV charging applications, which can be extracted from Google Play, shows the growth of the EV ecosystem and the wide distribution of the mobile application among consumers. This sheds light on the popularity and wide distribution of these applications that are used by many users. Moreover, the EVCSs and their management system in most cases belong to one or more different networks, thus allowing cross-application control. For example, the ChargePoint mobile application controls Blink, SemaCharge, and of course its own network. This highlights the importance of developing secure mobile applications due to its cross-operator collaboration, which adds more heterogeneity to the ecosystem, especially with the lack of standardization.

2.3 Related Work

In this section, we survey and discuss previous work that tackled the security of the EV charging ecosystem's components. The security was analyzed from various perspectives, one of which discussed the security software component and the communication protocols, and the implications of the security vulnerabilities on the infrastructure.

2.3.1 Software Components Security. Nasr et al. [7] studied and examined the security posture of the EVCSs and their management systems. They managed to find vulnerabilities across 13 severe vulnerability classes in firmware and management systems (mobile applications and websites). It is worth mentioning that in [7], mobile applications were analyzed using only static analysis, whereas our analysis utilizes both aspects to understand the interaction of the different components without taking into consideration the interactions of the components and design flaws. Moreover, outside of academia, the Kaspersky Lab team [17] analyzed the security of the ChargePoint home charging station and found significant vulnerabilities in its firmware and mobile management application. In our study, we provide a systematic and detailed analysis of the top 31 EV charging mobile applications. We are the first to address the lack of a comprehensive analysis of the EVCS mobile application, which plays an integral role in the EVCS ecosystem. It is worth noting that the mobile applications used to manage EVCSs are widely distributed and easily accessible, which simplifies and makes it easier for the attacker to acquire, analyze, and compromise, compared to firmware or cloud management systems.

Moreover, the communication links have been also studied in the literature. Alcaraz et al. [9] examined the communication protocol and presented a vulnerability in the OCPP that allows for MitM attacks, thus interfering in the communication between the EVCS and the EV resource reservation service. Moreover, in [18] they address the vulnerabilities presented in [9] and provide countermeasures. The security of the OCPP has been improved; various security measures have been implemented to harden the communication protocol such as the addition of secure firmware updates, security logging, and event notification and security profiles for authentication (key management for client-side certificates) and secure communication (TLS) [13].

2.3.2 Infrastructure. Sayed et al. [6] demonstrated the impact of compromising EVCSs on the power grid and launched attacks against it. They discussed the non-linear nature of the EV charging load and simulated multiple attacks that can be launched against the power grid using these EVs. While the grid was able to recover after a 48 MW attack utilizing traditional residential loads, a smaller 30 MW EV load attack was able to completely destabilize the grid. Moreover, in [19], the authors study how a botnet of compromised EVs and fast-charging direct current stations can be utilized to launch cyber attacks on the power grid and its implications on the transmission and distribution networks. Moreover, in [20–24], they study the implications of EV charging on the grid and discuss some mitigation techniques. In [25], they discuss the use of SMS phishing as a social-based attack, where an attacker can send spoofed text messages to the users advertising a discount (20% off when the users charge their vehicle at noon). Consequently, they studied the impact of such an attack on the grid. However, mobile phishing attacks require knowledge of the mobile phone numbers of EV users in a certain target area, which affects the feasibility of acquiring such information. Furthermore, in [25], the attack depends on the susceptibility of users to the demand-and-response phishing attack. In our study, we demonstrate how and when an attacker can get information to perform an orchestrated attack that might impact the stakeholders and study the feasibility of acquiring such information. Moreover, we demonstrate vulnerabilities that allow us to exploit the communication between the mobile application and the charging station. The discovered design flaws allow the adversary to charge any vehicle connected to an EVCS that could be used later in load-altering attacks.

2.3.3 Difference over Related Work. Zhou et al. [26] studied home IoT communication with the cloud to detect device interaction issues. They performed traffic analysis by intercepting mobile application traffic with the cloud and the IoT devices' interaction with the cloud. However, due to the limited access to the public EVCS infrastructure, we use functional analysis to monitor the EVCS state changes based on the mobile applications' user behavior. Moreover, we record user input in the application (e.g., user information, credit card, vehicle information) to understand the semantics of the traffic being sent. Utilizing traffic analysis similar to [26], the origin and the meaning of the traffic being sent would be lacking. The adversary in [26] needs to have access to the charging infrastructure to detect vulnerabilities; however, in our analysis, we only utilize the mobile application as a means to get information about the whole ecosystem. Furthermore, in [7], the authors focused on static analysis to analyze the vulnerabilities in mobile applications, which limits their ability to analyze the interactions of the ecosystem while utilizing the mobile application as an attack vector. To the best of our knowledge, analysis of the EVCS mobile application and its interaction with other components (CMS and EVCS) has not been done before.

2.4 Threat Model

To model the threat we considered different items to analyze and understand potential threats to the ecosystem. The items that were taken into account are:

- Assets: We consider the remote adversary with access to one or more mobile applications distributed on the Google Play Store and Apple store. Along with that, the adversary has access to online resources that aid in understanding the system architecture. This helps in understanding the value and criticality of the assets to help prioritize and scope the adversary's search for vulnerabilities.
- Entry points: The adversary then determines the entry points to the ecosystem. The attack surface considered in this work is the mobile application. Other attack surfaces that could be identified from the different assets are considered out of scope.

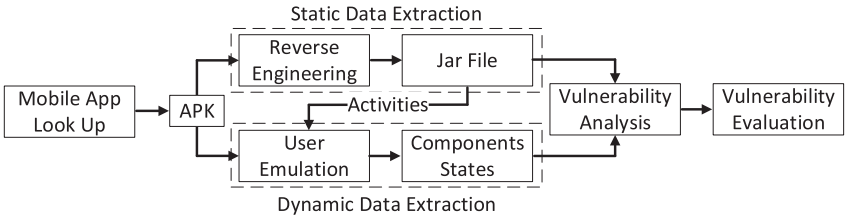


Fig. 2. The overall mobile application lookup and vulnerability analysis methodology.

- Trust boundaries: Identify the trust boundaries within the system, where different levels of access or privilege exist. Understanding the boundaries helps in evaluating potential threats associated with unauthorized access, the elevation of privileges, or trust exploitation.
- Threat actor goals: The attacker aims to utilize mobile applications as an entry point to target EVCSs with connected vehicles. The adversary's goal is to exploit design flaws in the interactions among the different entities (e.g., EVCS, CMS, mobile application) to hijack or initiate an unauthorized charging session remotely without compromising legitimate user accounts. Moreover, the adversary's ultimate goal is to leverage illegal charging sessions to perform large-scale, coordinated botnet attacks against the underlying critical infrastructure (e.g., the power grid) and the EV users.
- Threat actor: We consider the remote hacker that is able to create an account on EVCS charging mobile applications. Taking into consideration the threat actor goal, such large-scale attacks have been increasing lately where likewise state-backed attackers targeted critical infrastructure.

Additionally, similar to [26], we do not assume any forms of software bugs or protocol vulnerabilities. The adversary relies on understanding the interactions between the components by utilizing various analysis methods to identify vulnerabilities and understand the interactions between the mobile application and the CMS. The analysis methods range from reverse engineering and white-box testing to functionality analysis, system fuzzing, and black-box analysis.

3 METHODOLOGY

In this section, we elaborate on the analysis methodology to identify vulnerabilities that allow adversarial accounts to control charging sessions for vehicles they do not own. As shown in Figure 2, we combine static (reverse engineering and code review) and dynamic analysis techniques (functionality and traffic) to perform vulnerability analysis and assessment of the identified mobile applications. First, we start by fetching EV charging mobile applications, and then, for each product, we extract data for analysis by applying reverse engineering techniques on their binaries. Second, we extract network traffic during the functionality analysis while emulating the user behavior of the application; consequently, we analyze the application states and behavioral changes to abstract the system interactions and then evaluate it to find flaws. We provide details on the proposed methodology components below.

3.1 Mobile Application Lookup

In this section, we discuss our selection strategy for mobile applications. According to Statista [27], Android maintained its position as the leading mobile operating system for mobile phones with about 73% market share. We look for EV charging mobile applications on the Google Play store, which is the main platform used by Android users to download applications. Furthermore, we automatically fetch 50 mobile applications from the Google Play store. Then, we choose the mobile

Table 1. Types of EV Charging Mobile Applications Based on Their Abilities

Description	Type	Application Names
Remote control of charging sessions and system overview	1	**Remote Start Charging:** ChargeHub[a,b] - Electrify Canada[c] - PodPoint[a,b] - Electrify America[a,b] - EVDC[a,b] - Semma Connect[a,b] - eCharge Network[a,b] - Tata Power EZ Charge[c] - Flo EV Charging[a,b] - BC Hydro EV[a,b] - Circuit Électrique[a,b] - PlugShare[a,b] **Remote Start and Stop Charging:** Petro-Canada EV[a,b] - ChargePoint[a,b] - vend-electric[a,b] - Anywhere Charging[a,b] - Electromaps[a,b] - Ionity[a,b] - Volta Charging[a,b] - Charge Assist[a,b] - Virta[a,b] - Global Charge[a,b] - EV Charging by NewMotion[a,b] - EV Match[a,b] - EcoFactor Network[a,b] - FastNed[a,b] - EVgo[a,b] - Greenlots[a,b] - EVduty[a,b] - EV Connect[a,b] - NextCharge[a,b]
System overview	2	Zap-Map - Charge Map - EVMap - Kazam EV - Chargeway - Charge Finder - Open Charge Map - EV Stations
Home charging optimization	3	EV Energy - OptiWatt - Monta EV Charging

[a]Indicates the mobile application operators that possess Flaw 1 (Unverified Ownership). [b]Indicates the mobile application operators that possess Flaw 2 (Improper authorization for a critical function). [c]Indicates the mobile application operators that possess Flaw 1 and 2 but mitigate them by requiring information only found physically on the EVCS HMI.

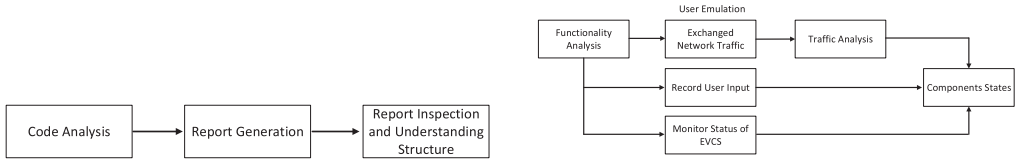
applications and filter them based on the features they possess by automatically searching the description for keywords such as start/stop charging. After further analysis, we discarded eight mobile applications that are either EV charging calculators or not related. Our analysis focuses on mobile applications that provide remote control functionalities to control public EVCSs; consequently, we analyze the applications manually to ensure the existence of these functionalities as they pose a real danger to the power grid when compromised at scale [6].

Based on the prior differentiation between the applications according to their capabilities, we identify and classify the applications into three types, as shown in Table 1. Type 1 applications allow users to have an overview of the ecosystem and control the charging session, while Type 2 applications are used to perform reconnaissance activities and can only show an overview of the system. Type 3 mobile applications are developed to target home EVCS owners or businesses with private EVCSs, limiting their impact, especially from a power grid perspective. Type 3 applications could possess vulnerabilities; however, it is considered out of the scope of this work as we focus on mobile applications that provide access to public EVCSs, thus increasing the impact of an attack on the power grid. Namely, we focus on Type 1 applications that can be used to perform attacks on the power grid because of their special capability to control the EVCS and its operations. Additionally, Type 1 and 2 applications can be used by an adversary to prepare for their attacks by analyzing the availability of EVCSs and their usage trends, as discussed in Section 4.4.

Finally, we fetch the remaining mobile applications and download/install their APKs. It is crucial to highlight that any security concern discovered in the communication between the mobile application and the CMS applies to both Android applications and iOS since they rely on the same back-end that handles their requests in most cases. Therefore, we assume that our analysis methodology and results can be generalized to both platforms, respectively. However, confirming this will be considered for future work.

3.2 Static Analysis

We aim at documenting and understanding the functionality of mobile applications and their utilized libraries. We used static analysis to understand the security measures implemented by EV charging mobile application vendors to thwart automated bot attacks by examining libraries and artifacts found in the binary files, along with understanding the structure of the mobile applications (Figure 3(a)) to perform a systematic functionality analysis. Thus, we utilize reverse engineering of the APK, which is an archive package that contains a manifest file with the package name, activity names, hardware features support, permission, and other configurations. The APK also contains



(a) Static (b) Dynamic

Fig. 3. Overview of the static and dynamic analysis methodologies.

the certificates for the application, a `lib` directory holding compiled libraries used by the application, and a file with compiled application code in `dex` file format, which can be interpreted by the **Dalvik Virtual Machine (DVM)** and the Android runtime environment.

We extract all the files using apktool [28], which disassembles all the resources and extracts the application Manifest and the `dex` files. Consequently, we use the extracted dex files and convert them to a `JAR` file using dex2jar [29] utility. We then input the file into jd-gui [30] to browse the underlying Java source code. We then analyze the extracted jar files using white-box analysis techniques to check the application resources (e.g., libraries and their functionality, certificate signing techniques used by the application developer, etc.). Further, we extract resources from the generated reports (e.g., the activities used in the mobile application and the flow of activities), which allow us to perform a detailed functionality analysis and identify libraries used in EV charging mobile applications by using MobSF [31] and LiteRadar [32]. Consequently, we check the functionality of the libraries used (e.g., Google reCAPTCHA, hCAPTCHA, Anti-location Spoofing). The understanding created by studying the information obtained through static analysis is used to systematically guide the following step, which is the dynamic analysis.

3.3 Dynamic Analysis

We rely on dynamic analysis (Figure 3(b)) to complement our static analysis method and provide a holistic and comprehensive assessment of all the interactions and functionalities provided by the mobile application. The dynamic analysis is performed through functionality analysis, recording user input, traffic analysis, and monitoring system state changes.

Functionality Analysis. We perform functionality analysis to collect data and identify system states to understand the communication between different entities. Specifically, we seek to answer the question of "How can the adversary utilize the interaction vulnerabilities and weaknesses to connect to a remote EVCS and control its operations?"

Guided by the static analysis that allowed us to understand the structure of each mobile application by mapping its activity flow, we attempt to systematically cover all the possible scenarios to systematically perform a detailed functionality analysis [33, 34]. We analyze each mobile application by manually mimicking regular users' behavior and operations and triggering every functionality possible in the mobile application. Throughout our analysis, we discover that some functionalities are strictly prohibited based on the location of the device. For example, Petro-Canada EV prevents initiating charging requests if the users' location is not in the vicinity of the EVCS. However, to mitigate that during our functionality analysis, we spoof the location of the device by broadcasting a location close to the EVCS. We utilized GPS JoyStick ADB Shell [35] to spoof the device's location. It is worth mentioning that other applications (e.g., Electric Circuit) notify the user that they are far away from the location of the charging station; however, this does not restrict the user from initiating a charging request. Furthermore, some applications (e.g., electromaps) detect that the user is far from the EVCS even if the location was spoofed. This is attributed to the IP-Geolocation services used to detect the location of the originating IP, which

can be circumvented using a VPN that routes our traffic through a private tunnel that appears to originate from the same country as the charging station.

Traffic Analysis. While emulating user behavior and performing user actions, we capture the traffic generated by the mobile application to understand the information that is being sent and the interactions between the mobile application and the CMS similar to [26]. We trigger important functionalities of the application such as sign-up/in and start/stop charging. However, most applications use trusted **Certificate Authorities (CAs)** to protect user privacy by encrypting the communication between the mobile application and the CMSs [26]. To decrypt the communication we utilize an un-rooted device with the Android 7 operating system.

Moreover, since Android OS with version ($\geq$ 7.0) does not trust user-installed certificates by design, to run applications on an un-rooted device with user-installed certificates, we create a virtual space on the phone that allows running Android APKs as plugins by utilizing VirtualXposed [36]. Consequently, we perform API hooking to bypass certificate pinning/verification by using Inspeckage Package Inspector [37]. Moreover, in some applications we bypass certificate verificationby reverse engineering the application using APKTool [28], followed by injecting code into the application. We then repack and sign the application before installing it. Consequently, we utilize Burpsuite [38], which operates as a proxy server between the mobile application and the target server to intercept, inspect, and modify raw traffic passing in both directions. Our analysis was not intrusive; however, it allowed us to unravel and understand the communication between the mobile application and the CMS.

4 RESULTS

We utilize different methods to infer and analyze the interaction of the main components within the EV charging ecosystem during user and device registration and when initiating charging requests. We extract the capabilities instilled in each mobile application. The capabilities recorded for each mobile application include remote start charging and remote stop charging. Moreover, we record the remote control restrictions that are implemented by the mobile application vendors to hinder the illegal or abnormal usage of a charging station. The vendors limit the flexibility for the user to initiate charging requests based on (1) location proximity of the users (i.e., must be near the target charging station to initiate requests), (2) IP Geolocation info (i.e., charging requests should originate from the same country/area as the target charging station), and (3) user-entered charging station ID that is found on the target device.

Our preliminary analysis shows that all applications provide their users with a remote start charging service. Moreover, only 13 (e.g., Flo EV Charging, Plugshare, etc.) mobile applications do not provide stop charging functionality, forcing users to remove their cars when they finish charging. It is important to note that only two applications (Petro Canada EV and Electromaps) check the integrity of the users by validating the location of the device, whereas only one application (Electromaps) checks the locations of the originating IP of the charging request. Finally, two applications force the user to input a station ID or scan a QR code to initiate charging (Tata Power EZ Charge and Electrify Canada).

4.1 Inferred Interactions

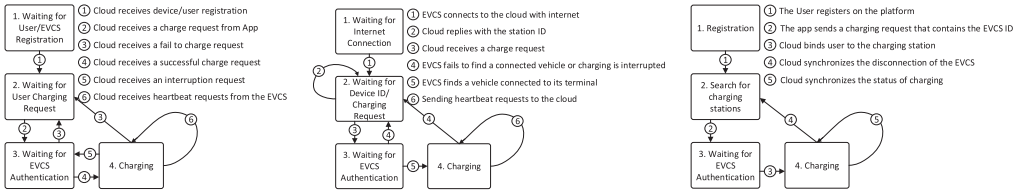
As described in Section 3.3, we leveraged dynamic traffic analysis to capture and infer the interactions between the mobile application and the CMS. As an adversary, we consider the communication between the EVCS and the CMS as a black box. However, the communication between the other entities can be inferred from the different states that the mobile application goes through while performing different actions. Moreover, while previous works presented in [7, 9, 13, 14] complement our analysis of the communication between the EV, EVCS, and CMS, they provide

us with some additional insights about such communication and interactions. Specifically, it has been shown that the communication between the EV and the EVCS lacks proper security measures, which renders the underlying equipment vulnerable to remote attacks. For instance, Baker et al. [14] were able to eavesdrop on the **Pulse-Width Modulation (PWM)** communication, which is utilized by IEC 61851 [39, 40] for safety-related signaling mechanisms between EVs and EVCSs. Furthermore, despite the added security features in the ISO/IEC 15118 (e.g., Signal-level Attenuation Characterization and TLS encryption), the works in [14, 39, 40] highlighted the improper deployment of these features in practice. Moreover, as highlighted in [6], most of these security features are optional and are commonly ignored by manufacturers, thus rendering devices vulnerable in real life.

User and EVCS Registration. To this end, we analyzed the EVCS charging applications listed in Table 1 of Type 1 to infer the interaction between the different entities upon user registration, EVCS registration, and sending a charging request. We identify the main interactions with the CMS during the registration of a new user and an EVCS. During user registration, each user is assigned a unique identifier, which allows the user to log into the platform and use existing functionalities. There are several options for the user identifiers such as email/password combination or authentication tokens to name a few. The unique user identifier is transferred to the CMS upon user registration on a given platform and then used later for authentication purposes. On the other hand, when an EVCS is installed and made available for the public, the operator needs to register it with the CMS by sending/registering its unique identifier. This information gets saved in the CMS and used by the mobile application to identify a charging station.

Initiating Charging Requests. After the user connects the vehicle to the charging station using one of the available connectors, the user must initiate a charging request using the mobile application by selecting the desired charging station (e.g., using a map view). The application embeds the unique user identifier along with the selected station's ID in the message sent to the CMS, respectively. The CMS then sends a start charge request to the charging station with the respective ID/info. Consequently, the EVCS checks for any connected vehicle before initiating the charging session. Note that in case no vehicle was connected at the time when the user initiates a charging request, the EVCS will wait for a grace period (e.g., 5 minutes) to provide the EV owner with sufficient time to plug the charger into the vehicle. Otherwise, if a car was found to be connected to the EVCS, it will initiate the charging session by sending a confirmation message to the CMS; this is inferred by monitoring the changes on the mobile application user interface. Once the CMS receives the confirmation, a correlation between the user identifier and the EVCS identifier is established. Finally, the CMS relays the charging confirmation sent by the EVCS to the mobile application.

To put this in a better context, we describe the state transitions inferred from the analysis of different platforms provided by the various EVCS operators in the industry. We validated the interactions that helped us derive the states of the components on a real-time co-simulation test bed and two EVCSs acquired from one of the biggest North American operators. Any action triggered on the mobile application has a cascading effect on the other components and will alter the state of the other components. For example, whenever a user initiates a charging session from the mobile application and transitions from S2 to S3 as illustrated in Figure 4(c), the EVCS and the CMS will transition from S2 to S3 and eventually S4; the state of each component is dependent on the actions done by the other components. The different components making up the EVCS ecosystem are tightly coupled. The transition of one entity from one state to the other would change the current state of the ecosystem. An ideal system must strictly maintain the three-entity state machine. The legitimate states of the EVCS ecosystem are depicted as a 3-tuple combination. The CMS, EVCS, and mobile application must strictly maintain the following 3-tuple states at all times to avoid potential attacks. For example, if an attacker is able to induce the cloud and the EVCS to transition



(a) Cloud management system (CMS) (b) EV charging station (EVCS) (c) Mobile application

Fig. 4. High-level state machines for the three interacting components within the ecosystem.

to state S3 while the legitimate user is still in state S2, this shows that the charging session was hijacked by a third party (adversary). Moreover, another 3-tuple state if triggered can also lead to similar consequences by forcing the cloud and the EVCS to transition to state S4, whereas the legitimate user mobile application is in state S1 or S2. Whenever a legitimate user is looking to charge his or her vehicle using a certain EVCS, the cloud state and the EVCS state should allow future transitions rather than being blocked. If user B is charging, user A is not allowed to access the EVCS remotely. Note that all components have the same numeric state at all times, except at S1, where the CMS can be in S1 while the other components could be in either S1 or S2. Consequently, through this work we aim at dissecting the intricate interactions of the components to trigger illegal states. The state machine shows the general operation of the EVCS ecosystem and shows the type of information that is shared during the process. Thus, through our analysis, we identify several vulnerabilities related to the trust model adopted in these ecosystems. Moreover, a deep understanding of a system allows us to identify flaws in the ecosystem design that are related to how the components interact with each other. Thus, we performed a systematic unraveling of the different components and their interactions.

4.2 Identified Vulnerabilities

In what follows, we present examples of the identified vulnerabilities that can be exploited to perform remote attacks against the EV charging ecosystem and the various involved stakeholders (e.g., EV consumers and the power grid). We leveraged the described analysis methodology in Section 3 along with the inferred traffic/interactions in the previous sub-section to identify vulnerabilities.

Specifically, we discovered three major security weaknesses that are inherited from design and implementation flaws in the studied EV charging mobile application (Type 1). The EVCS charging platform does not strictly comply with the legitimate 3-tuple states. We found that the three entities stay in multiple unexpected 3-tuple states. The first unexpected state is (S4, S4, S1/S2); the CMS and the EVCS transition to the charging state, whereas the mobile application user is either still in registration or EVCS discovering state. This illegal state combination when exploited by an adversary could allow for remote charging/discharging session hijacking.

In what follows, we elaborate further on the root cause of such behavior, the identified vulnerabilities, and their implications. It is worth noting that some mobile applications (e.g., EVMatch) mitigate the first unexpected state by forcing the user to reserve a spot beforehand. Other applications (e.g., Tata Power EZ Charge) hinder remote hijacking by forcing users to scan a QR code on the EVCS. However, when statically analyzing the mobile applications, QR codes are saved in a temporary file in the external SD card, which allows an on-device attacker to get access to that information to hijack the charging sessions. It is worth noting that some applications hide the access to charging behind a payment gateway (e.g., buying store credit). However, adversaries can overcome this by buying store credit, which will provide access to the charging infrastructure. In what follows we focus only on the flaws that can be used to manipulate the EVCSs for attacking the grid.

Flaw 1 (F1): Unverified Ownership. Ideally, an EV user should be the owner or authorized user of the vehicle. Thus, the EV user should be the sole entity to authorize any form of control or action on the vehicle. Interestingly, our static and dynamic analysis results indicate that the mobile applications do not verify user ownership over target vehicles when initiating charging requests. In other words, an EV charging mobile application user can initiate a charging request to any vehicle connected to the network since neither the mobile application nor the CMS has a mechanism to bind the application user to the target vehicle. Given that all communications of the mobile application go through the CMS, it is imperative to have the CMS verify critical operations such as vehicle identification and ownership management. On the other hand, access to vehicles from an unauthorized user is not verified within the EV charging mobile application platforms, therefore rendering the EV exposed to any user who can claim ownership and control over its charging functions when connected to the EVCS. This leads to unexpected behaviors and potentially exploitable states.

Flaw 2 (F2): Improper Authorization for a Critical Function. Starting and stopping charging operations on a given EVCS are considered examples of critical functions that could be abused by adversaries (unauthorized users) to destabilize the operations of the EVCS and the connected power grid. This was clearly demonstrated in [6], where the authors measured the impact of mass charging and stopping operations on the power grid. Ideally, an EV owner/operator should be the only user authorized to perform critical functions on the vehicle. Exposing critical functionalities essentially allows adversaries to control charging sessions, which is considered as the first step toward initiating mass charging attacks on the grid. Nevertheless, our analysis results indicate that there is a lack of authorization, which allows any actor to perform critical functionalities on the connected EVs. This is closely related to our first finding (F1); it is mainly due to the fact that the binding step happens only based on the user and charging station IDs without further verification of the EV ownership or binding to specific mobile users. Therefore, an adversary can utilize fake accounts to hijack sessions.

4.3 Attack Scenarios

An attacker can leverage the discussed vulnerabilities to launch various malicious activities against the EVCS and its operations such as remote charging session hijacking. To do this, attackers need to control a number of adversarial accounts (i.e., bots), which provide access to existing charging services through mobile applications. Note that adversaries do not need to exploit or hijack user accounts to create the required botnet. The attackers can easily create their own botnet of legitimate mobile application accounts. The only security measures in place rely on SMS or email authentication/verification during account creation (e.g., one-time password and email verification). In practice, an attacker could rent service from online SMS and e-mail providers such as Twilio [41], which provide communication APIs to handle the verification processes. Additionally, attackers can create as many fake email accounts as needed for the verification process.

Remote Charging Session Hijacking. After analyzing the interactions of the mobile application with the different entities, we developed an understanding of how the mobile application could be used as an attack surface against the power grid. We found that the studied platforms are vulnerable to session hijacking. By utilizing these vulnerabilities, attackers can initiate unauthorized EV charging sessions with the aim to impact the power grid. Ideally, the CMS should only allow a charging request if the request is issued from the account owner that is bound with the EV. However, we found that the CMS does not perform any account-based authorization or check during charging. In other words, there is a decoupling between the user account and the EV that is connected to the EVCS. The user is coupled with the EVCS ID only. Thus, an EV connected to an EVCS can be charged remotely regardless of whether the user initiating the request is the

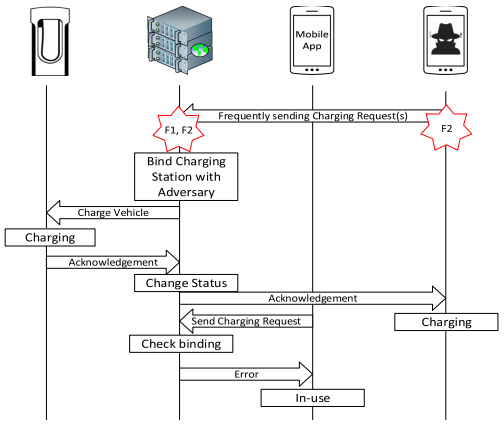


Fig. 5. Sequence diagram depicting remote charging/discharging scenario.

legitimate owner of the EV. The CMS does not perform the necessary checks to validate whether a user is allowed to perform this action or if the user is the actual owner of the EV, thus allowing adversarial accounts to unlawfully hijack charging sessions.

As illustrated in Figure 5, the adversary can leverage the combination of F1 and F2 to initiate unauthorized charging requests to take control over the charging session that should have been initiated by the actual EV owner. When the attacker uses an adversarial account to start charging requests, the CMS will establish a connection with the adversary. It is worth mentioning that the actions performed by the adversary are fully legitimate and within the scope of the permitted functionalities of the ecosystem. Consequently, legitimate EV owners can no longer control their charging session. The only way for the user to stop the charging is by physically unplugging the EV. The adversary utilizes the mobile application as an attack surface against the ecosystem. The adversary creates legitimate accounts and lurks in the system, monitoring the behavior of victim EVCSs to be targeted. The adversary studies the behavior of the EVCS through its status that is shown through the application. The behavior allows the adversary to understand peak hours when the EVCS is mostly utilized and discover when users usually use the EVCS. The attacker can then stage their attack by targeting peak hours to increase the success rate of the attack as described in Section 4.4. The adversary leverages the unverified ownership of a user over the vehicle they are trying to charge and the lack of authentication on this critical function to send charging requests.

After the user's charging session has been hijacked, the user can no longer control the EVCS. While this could raise an alert for a security-savvy user, other users may simply disregard this behavior as long as they see that their EV is charging. It is worth mentioning that even the security-savvy users will not notice the attacker's actions unless they regularly check their mobile applications during the charging process. Additionally, even when the attack is noticed by these users, the root of the problem cannot be traced back to the adversary. Only the CMS has the knowledge to trace back the attack's origin. However, due to F1 and F2, the attacker's actions are considered legitimate.

We describe in Table 1 the possible attack scenarios based on the functionalities instilled in the mobile application, showing that 29 out of 31 mobile applications are vulnerable to remote mass charging attacks. We exclude Tata Power EZ Charge and Electrify America as they require inputting the EVCS ID number that is physically placed on the charging station HMI. Moreover, there are only 19 out of the 31 mobile applications that provide remote start and stop of

charging and allow adversaries to launch oscillatory load attacks with their advanced control on the stopping of charging.

Remote Discharging. Vehicle-to-Grid (V2G) capabilities are one of the attractive features of EVs that can one day transform the EV battery into a distributed storage to support the power grid operation. Willing EV owners would register themselves as users willing to contribute to supporting the grid during peak hours for an incentive (e.g., financial incentives larger than the cost of charging) through utilizing their mobile application. However, as demonstrated above, the current system architecture lacks traceability and end-to-end authentication. An adversary can hijack a session, as explained above, and register themselves as a legitimate user that is willing to contribute to such a V2G scheme. This allows the adversary to gain monetary compensation by discharging other users' vehicles. We acknowledge that such a class of attacks is not currently feasible due to the shy adoption of V2G capabilities and the absence of wide-scale compensation programs. However, the advancement toward such capabilities being instilled in the ecosystem requires improving the current ecosystem architecture and strict access control mechanisms for safe and secure operation.

4.4 Attack Feasibility

In this section, we study the feasibility of launching wide-scale coordinated charging/discharging attacks. In these attacks, we assume that users connect their EVs to EVCSs before starting a charging session. We also assume that the vehicle remains connected for a period of time after the end of the charging. In the aims to understand user behavior and predict it, the authors in [42] highlight that EV owners do not necessarily start charging right after plugging in. Additionally, a time window exists between plugging in and charging an EV, which is the time a user needs to pull out the phone to start a charging session. Moreover, according to Almaghrebi et al. [43], another time window exists where customers leave their vehicles for an extended time when parking at the workplace or overnight beyond finishing charging. Some users even leave their vehicles for longer than 24 hours. This attack window is only applicable to mobile applications that provide remote start and stop services. These time windows are exploitable by the adversary that can utilize them to launch remote session hijacking.

In [44], the authors utilize a multistep hybrid LSTM neural network to predict EVCS occupancy. They base their analysis on public charging data from the city of Dundee, UK, in 2018. The number of charging stations plugged in simultaneously during the day fluctuates, reaching 300 charging sessions at 10:00 AM during the weekend and 400 charging sessions during the weekday. The number of charging sessions starting at peak times during the day is expected to increase as more customers adopt electric vehicles as a means of transportation with the rapid and increased deployment of public charging stations. Thus, the feasibility of remote charging session hijacking at scale increases.

4.5 Attack Demonstration and Verification

To execute an attack by exploiting these vulnerabilities, an adversary needs information about the user's behavior. By understanding user behavior, the adversary can time and coordinate the attack to increase its success rate. The attacker can extract information from the mobile applications (Type 1 and Type 2) similar to [45], where the authors predicted user behavior based on arrival time, duration, departure time, and so forth. An adversary can utilize the online interface (mobile application/web portals) to gather information. The information we gathered through a tool we devised is the start charge time (arrival time) and departure time if a vehicle connected within the attack windows. We used Appium [46] to automate mobile application scraping, which can be used for web application scraping. We then identify target EVCSs and monitor their utilization

and status. We collect information about the EVCSs that are in use, allowing us to track arrival and departure times. Moreover, whenever the station's status changes from "in use" to "available," we send a probe charging request to check if there is an EV connected to the EVCS. The collected data is used to model user behavior and allow us and the attacker to target peak EV connectivity hours to hijack charging sessions at scale [44].

In this section, we evaluate and verify our observations, inferences, and conclusions by using a real-time co-simulation test bed. We create a replica of the real EVCS ecosystem by integrating real charging station hardware with a production-grade CMS. The EVCS hardware utilizes OCPP v1.6 and communicates with the CMS backend to perform device registration initially. The EVCS and the CMS then continuously communicate with each other over WebSockets to ensure that the EVCS is alive by either sending a heartbeat notification or through the WebSockets ping-pong request/response. Indeed, during device registration, the EVCS will send an HTTP request to the CMS backend, which gets upgraded to a WebSocket connection. The HTTP header includes the EVCS identification number, which could be the serial number or an operator-defined ID as demonstrated in Figure 6. Consequently, we were able to confirm and verify our observations and inferences regarding the interactions of the different components discussed previously.

Accordingly, we aim to demonstrate our new attack vector to verify our conclusions on the vulnerabilities that exist in the EVCS mobile operators. To leverage the aforementioned design flaws that rely on the authentication scheme adopted by the different EVCS mobile operators, we first identify two EVCSs mainly in heavily populated areas. We monitor these EVCSs and record their utilization by gathering information from the mobile interface of the applications for 3 days starting on November 8, 2022, till November 10, 2022. During that time we performed reconnaissance to understand the utilization of the EVCS. $EVCS_1$ showed heavy arrival during evening hours (between 6:30 PM and 7:30 PM), whereas $EVCS_2$ showed heavy arrival between 4:00 PM and 5:00 PM. To identify the utilization and arrival, we note the change in the state of the EVCS. When charging an EV, the EVCS shows an "in-use" state, rendering it unavailable to other users. Consequently, on November 11, 2022, we execute our attack as a proof of concept on the EVCSs. We leverage the lack of rate limiting to send multiple charging requests every 3 to 4 minutes from the adversarial account we created using the legitimate mobile application channels. After sustaining the attack for almost 30 minutes starting at 6:30 PM for $EVCS_1$ and starting at 4:00 PM for $EVCS_2$, consequently, at 7:01 PM and at 4:18 PM we were able to successfully hijack the charging session of the $EVCS_1$ and $EVCS_2$, respectively. We show in Figure 7 the confirmation of a successful charging of a vehicle that does not belong to us for almost 3 hours. Moreover, the attack was demonstrated and verified on two different mobile applications, i.e., one that only allows a start charge functionality and another that allows remote start and stops charging functionality. We also note that vulnerabilities that allow the adversary to remotely start and stop a session could be used in combination with other high-wattage IoTs to impact the power grid. In [47], the authors demonstrate the impact of controlling a large botnet swarm of high-wattage IoTs that could be used to impact the power grid by launching load-altering attacks. Load-altering attacks impact the power grid by inducing grid instability (e.g., frequency instability). Finally, the same attack workflow could be launched to impact the power grid using the other mobile applications as they follow the same procedures and policies to authenticate users.

We illustrate in Figure 8 the components of the co-simulation platform we have developed. The co-simulation platform is composed of cyber-components connected to the physical counterpart resemblling Hypersim, which simulates the power grid for physical impact studies. Moreover, real EVCSs are included in the simulation and are connected to the actual power grid to evaluate and verify our cyber layer observations, inferences, and conclusions. The mobile application is an essential component for the commercialization of the EVCS ecosystem. It provides different remote

```
GET /ocpp/[redacted] HTTP/1.1
Host: [redacted]
Upgrade: websocket
Connection: Upgrade
Sec-WebSocket-Key: yc00jOdENekBP7wdb6P1lg==
Sec-WebSocket-Version: 13
Sec-WebSocket-Extensions: permessage-deflate; client_max_window_bits
Sec-WebSocket-Protocol: ocpp1.6
User-Agent: Python/3.10 websockets/10.3

HTTP/1.1 101 Switching Protocols
Date: Thu, 08 Dec 2022 18:46:11 GMT
Connection: upgrade
Upgrade: websocket
Sec-WebSocket-Accept: SX/d29VizNfPapmpmC4xjyxGHQI=
Sec-WebSocket-Protocol: ocpp1.6
```

Fig. 6. EVCS device registration with the CMS using our real-time co-simulation test bed.

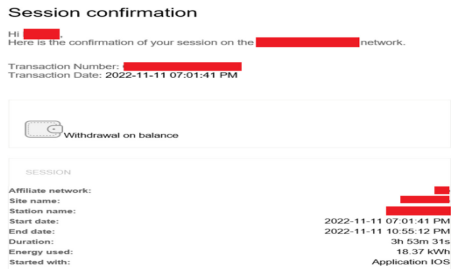


Fig. 7. Session confirmation showing the success of our attack by hijacking the charging of an idle vehicle.

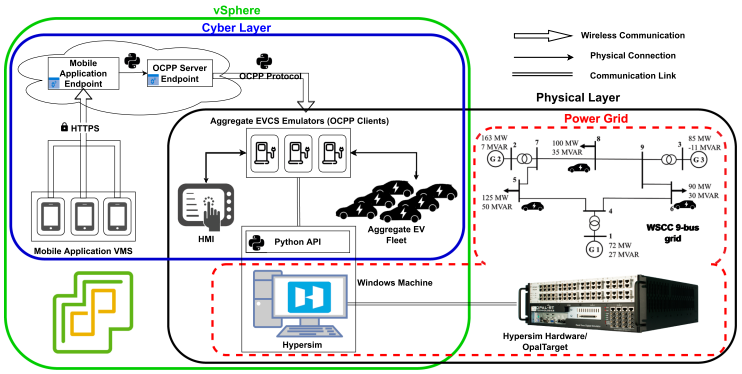
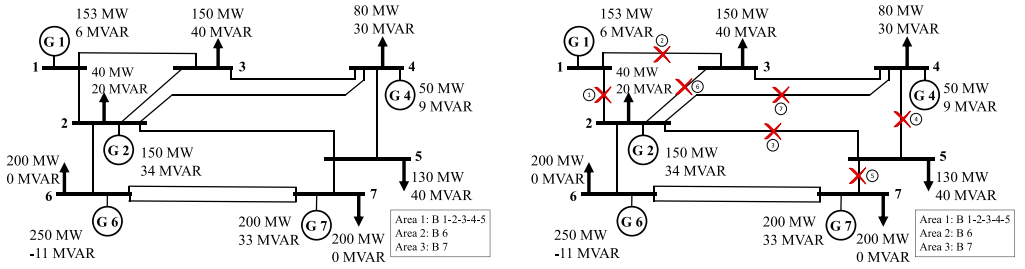


Fig. 8. Co-simulation architecture [48].

Table 2. Specifications of the Real-time Co-simulation Test Bed

Technology	Specification
vSphere ESXi	Version 6.0.0
Hypersim	Version 2022.1
Hypersim Simulation Step Size	25 µs
OpalTarget	OP5707XG - RCP/HIL Virtex-7 FPGA-based Real-time Simulator
EVCS VM	1 GB 1 CPU
CMS VM	1 GB 1 CPU
Mobile App VM	1 GB 1 CPU
Python Interface	Python 3.7

capabilities of starting, stopping, and scheduling charging. For the current implementation, we focus on starting and stopping functionalities. Moreover, as for the EVCSs, we use both simulated and real hardware that are part of our co-simulation environment. The EVCS VM runs a client-side OCPP developed using Python along with the CMS we developed that runs a server-side OCPP, which is used to manage the EVCSs remotely. The OCPP implementation has been validated with a production-grade EVCS and CMS provided by our partner Hydro-Quebec as part of a legal agreement and research collaboration. The CMS also provides a mobile application endpoint that is responsible for sending and receiving requests from the mobile application VMs. The specifications of the co-simulation platform are summarized in Table 2. Further details of the co-simulation platform can be found in [48].



(a) Glover book 7-bus grid (b) Line tripping attack impact

Fig. 9. Overview of the (a) Glover book seven-bus grid and (b) the impact of the line tripping attack scenario.

5 ATTACK IMPLICATIONS

In what follows, we discuss the remote charging session hijacking attack scenario along with its implications on the power grid and EV users, respectively.

5.1 Attack Implications on the Power Grid

As demonstrated in the analysis, attackers can leverage the identified vulnerabilities to compromise user accounts and perform synchronized large-scale cyber-attacks against the integrated infrastructure [5, 7, 49, 50]. With the EV charging ecosystem being a new and wide attack surface, it is an attractive target for exploitation by organizations with enough resources to conduct large-scale attacks against the power grid by utilizing the mobile application to perform stealthy attacks.

Consequently, an adversary could initiate a distributed botnet attack utilizing thousands of malicious accounts to send charging requests and hijack as many sessions as possible to amplify the attack. The behavior of arrival and departure at charging stations almost coincides with the demand behavior of the power grid [45], as demonstrated in the utility demand curve of California, United States [51], and New South Wales (NSW), Australia [52]. Additionally, by exploiting the identified vulnerabilities and initiating the remote charging session hijacking attack (Section 4.3) during the described attack windows (Section 4.4), an adversary can remotely orchestrate hijacked charging sessions to synchronize a wide-scale attack that can disrupt the power grid operations.

In this section, we study the impact of synchronized mass charging attacks on power system economics (i.e., generation cost and transmission line losses). We then examine how adversaries with some knowledge of the grid topology can craft targeted mass charging attacks in order to overload and trip transmission lines. Finally, we study the power grid stability subject to oscillatory load attacks that can cause violation of the safe frequency operation limits and load shedding. Oscillatory load attacks can be performed using 19 of the applications that provide on-and-off remote control capabilities without requiring the user to scan a QR code.

To amplify the attack impact on the grid, an adversary with knowledge of the grid can craft targeted and smarter attacks. A small number of compromised charging sessions with enough knowledge of weak buses allow the adversary to disrupt the power grid operations. Power grid information can be estimated through monitoring the measurements of the power grid to estimate the topology, using MILP programming, machine learning, and voltage and load monitoring [6, 53–59]. Various stability techniques and strategies could then be used by adversaries to locate the most sensitive/vulnerable buses, such as PV and QV curves [6, 60].

We demonstrate the impact of the attacks on the seven-bus test case introduced by Glover et al. [61] (Figure 9(a)), which is commonly used for research purposes [6]. We utilize this grid due to its built-in optimal power dispatching capabilities, unlike the work in [7]. Moreover, this seven-bus test case provides the generation cost formulas that will allow us to study the economic

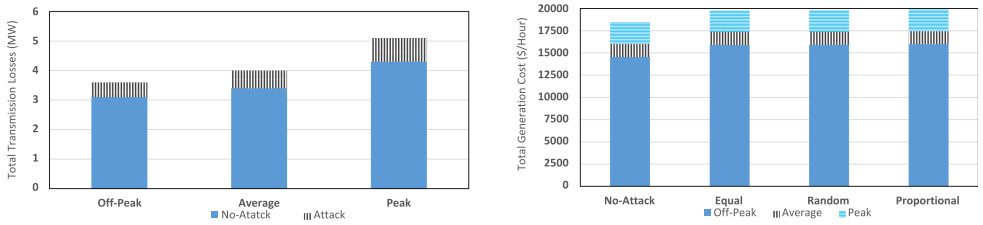
impacts on the utility. To achieve a close-to-realistic simulation of the power grid behavior during peak and off-peak demand hours, we scaled the grid loads based on the NSW [52] power grid load profile using Equation (1):

$$HourlyLoad_{Scaled} = \frac{GloverLoad \times HourlyLoad_{NSW}}{AverageLoad_{NSW}}. \quad (1)$$

To this end, we use PowerWorld [62], which is a power simulator that allows us to analyze the steady-state power flow, transient stability, generation costs, and other power system operations. Additionally, the stability studies are initially performed in PowerWorld and then validated using our real-time co-simulation test bed depicted in Figure 8. Unlike [6, 47], here we study the economical aspects of an attack such as generation cost and line losses, respectively. Along with that, we also take into account the load shedding mechanism that is used by the utility to regulate power generation in case of a sudden drop in frequency below certain thresholds [63] to demonstrate more realistic attack implications. The different attack simulations and results are demonstrated below. In what follows, the attack is initiated by compromising 84 MW of EV load, which is equivalent to 7,636 EVs charging at the 11 kW Level 2 chargers. The current numbers of EVCSs and EVs are not enough to mount such attacks; however, the growth in the EV numbers will soon provide a large enough surface to make it possible [6]. It is worth noting that mobile applications allow cross-product communication and control, thus increasing the scale of the attack as more vendors join these platforms. Moreover, as the EVCS market move toward wide adoption of Level 3 chargers, the higher power entails higher risk.

Economical Impact. The attacker can cause the power utility to incur economic losses by launching EV attacks against the power grid. To study the economic impacts of a mass charging attack on the grid, we examine the transmission line losses and the power generation cost during different loading conditions and under different attack scenarios. To perform mass charging attacks, 29 applications allow us to perform such an attack, whereas the rest prevent remote mass charging by forcing the adversary to scan a QR code. We used the scaled load profile to demonstrate the incurred cost and losses at different grid loading conditions. Namely, we focused on the peak load (943 MW), the average load (800 MW), and the minimum load (677 MW) conditions that we will refer to later as off-peak load. We simulate three different attack scenarios against the test grid by (1) distributing the attack load randomly, (2) distributing the attack load equally among the six load buses, and (3) distributing the attack load proportionally among the different load buses. It is worth highlighting that Scenario (1) represents a random distribution of the EV charging attack load to simulate an adversary with no knowledge of the grid topology. Scenarios (2) and (3) represent attacks by an adversary with limited knowledge of the grid and geographical knowledge of load size and EV distribution, respectively.

Generally speaking, the attacks will increase the transmission losses under all loading conditions. However, under higher loading conditions, the same attack will cause more incremental losses due to the increased power flow in the lines. Line losses are calculated as $P_{loss} = R_{line} \times I^2$; thus, at higher loading conditions, the same attack load will result in more losses. It is worth noting that under the different attack scenarios, the total incremental line losses were almost equal. This is due to the fact that the total load of the different attack scenarios is the same and that we do not have any extra long transmission lines that will have significantly different losses under different attack load distributions. The normal and incremental losses are demonstrated in Figure 10(a). The no-attack losses under the different loading conditions were 3.1 MW (off-peak), 3.4 MW (average), and 4.3 MW (peak), which led to an increase of 16.13% at off-peak loading conditions, 17.65% during average loading conditions, and 18.6% during peak conditions. Thus, this simulation clearly demonstrates that the attack impact on system losses is amplified when the power demand is the



(a) Transmission losses (b) Attack-related costs

Fig. 10. Incurred (a) transmission losses and (b) costs due to various attack scenarios.

highest, which also coincides with the time during which EV connection to the chargers is the highest.

In the case of attacks against generation cost, each attack scenario differs based on the optimal power dispatch performed by the utility to reduce the overall cost. Figure 10(b) presents the total generation cost of the system when no attack occurs and during the three attack scenarios mentioned above. As Figure 10(b) demonstrates, the total added cost due to the attack is higher during peak loading conditions across all attacks. More importantly, the proportional attack scenario caused the highest extra cost. To put things into context, the no-attack cost at off-peak, average, and peak loading conditions was $14,545.28/hour, $16,009.39/hour, and $18,438.10/hour, respectively. The added cost due to the proportional attack was $1,423.83/hour under off-peak conditions, $1,426.45/hour under average conditions, and $1,451.95/hour under peak conditions. This demonstrates how an attacker can force the utility to increase its generation and incur extra costs.

One aspect not present in the simulation was the usage of peak generation units. This was left out due to the absence of these units in the Glover grid in Figure 9(a). These units are usually fast-ramping units used by utilities and power grid operators during peak hours when the large baseline generation units do not have sufficient capacity to supply all the load. These peak generation units are usually operated for a few hours a day only due to their high operation cost. This means that if the attack occurs at a time when peak generators are being utilized, the extra cost would be higher. Another aspect of repeated long-term attack worth mentioning is that mass charging attacks, especially at peak hours, will cause extra transformer loading. This extra loading would reduce its lifetime and would require more frequent maintenance intervals, causing extra maintenance costs.

An attacker with a long-term target of causing the utility to incur extreme losses can repeat the hijacking of charging sessions over long periods of time. For instance, launching the above attack for 1 hour during peak times every day for an entire year will create an extra generation cost totaling $529,962 for the utility based on the Glover grid and the generators' cost functions. To put things into a better context, scaling this attack up to the NSW grid will cause a $4,615,967 extra cost for the utility per year. To this end, an attacker might choose to compromise a smaller number of EV charging sessions and choose different sets of EVs every day to remain stealthier and still cause millions of dollars of losses to the utility in extra generation costs.

Mass Drop in Load. The attacker can also initiate a different type of attack consisting of a mass drop in load. This attack can be initiated through the 19 mobile applications that allow the attacker to control both the start and stop of the charging session. The attacker would first start by gradually increasing the EV charging load in the grid in a manner that does not cause any stability issues to the grid. Once the attackers achieve the desired botnet size that is concurrently charging, they will initiate the mass drop in load. Figure 11 demonstrates the impact of a 40 MW drop in EV load equivalent to 3,636 EVs charging at 11 kW EVCSs that stopped charging simultaneously. It can be observed how the frequency initially spikes to 61 Hz before the grid eventually regulates back

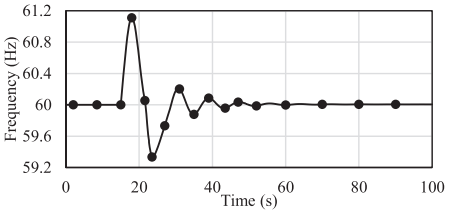


Fig. 11. Mass drop in load attack impact.

to the normal operating point of 60 Hz after 30 s of oscillations. A larger drop in load would result in larger-frequency deviations, but eventually the system would be able to recover from such an event.

Overloading and Tripping Transmission Lines. Another type of impact that might be desired by the attacker is causing line overloading and tripping by crafting a targeted attack against the grid. This attack has more severe and immediate consequences since it can leave consumers without electricity. In the previous set of attacks, some lines got highly loaded, but none of them reached an overloaded state. The same EV load, however, can be used by attackers with topology knowledge to target certain lines in order to cause cascading line failure. The attacker will only require knowledge of the topology and estimate values of the loads and power flows but not the line parameters. This information can be found online and in multiple public access databases and websites.

To simulate such attacker behavior, we targeted bus 4 and bus 5 with a synchronized 20 MW and 64 MW EV charging attack, respectively. This attack overloaded and tripped the line connecting bus 1 and bus 2, after which multiple lines would be overloaded and tripped. In total, seven lines would trip successively in the order shown in Figure 9(b). The successive line tripping would lead to islanding each of buses 1, 3, 4, and 5. While the load at bus 4 will be supplied by power from the generator at the same bus, the loads at bus 3 and 5 will lose their power supply and thus the grid will lose a total of 280 MW, which represents a loss of electricity to 35% of the consumers.

Power Grid Instability. Another attack that takes advantage of load manipulation is an oscillatory load attack that can impact the frequency stability of the power grid. This attack revolves around the concept of creating a demand surge to cause a frequency drop on the grid followed by a drop in demand to cause the frequency to overshoot. In the first step, the attacker will use the compromised accounts and hijack charging sessions to initiate mass charging to increase the power load. This extra power load would create an imbalance between the increased load and the generated power, causing the generators to slow down, resulting in a frequency drop. The second step of this attack happens when the system starts its recovery. The attacker would switch off the compromised charging sessions, initiated in the first step, to cause a frequency increase that is amplified by the operator's effort to increase the speed in response to the initial step. The attacker would then alternate between these steps for the desired duration. The impact can be amplified by launching the attack when the system has lower inertia due to the presence of a high share of renewable energy resources.

Given the dependence of the grid's transient behavior on the generator and turbine models, we utilized the automatic control models common to studies similar to ours. It is important to note that the utilization of different control models will change the exact values of the simulation, but the general shape and behavior remain the same. This demonstrates that the attacks can be successful under different conditions, but their magnitudes might need to be scaled based on the different conditions to achieve the desired impact. In our study, we used the machine model "GENSAL," the exciter model "IEEE T1," and the turbine governor model "IEEE G2."

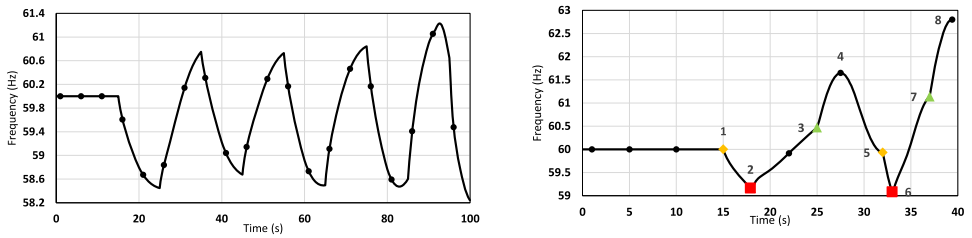


Fig. 12. Frequency behavior over time (a) without load shedding and (b) with load shedding.

The oscillatory load attack is simulated against the grid in Figure 9(a) by initiating the oscillatory load behavior described above on buses 3 and 5. The attack is initiated by starting a mass charging session equivalent to 20 MW (at time t = 15 s) and stopping it at t = 25 s after the system starts to increase generator speed to compensate and the frequency starts to rise. This charging and stopping behavior is repeated periodically every 10 seconds while increasing the attack load at each bus by 5.5 MW every cycle. The frequency behavior of the grid that results after such an attack is demonstrated in Figure 12(a), where we can see the frequency fluctuation due to the oscillatory load behavior. The importance of this attack is that it does not require huge loads to cause the frequency fluctuations depicted in Figure 12(a). Even when the compromised EV numbers are much less than in the example above, a sustained oscillation will hinder the system's return-to-normal operation. Sustaining this attack would damage the turbines due to the constant acceleration and deceleration.

In the previous example, we assumed no grid protection mechanism was used by the utility and that the attacker followed a semi-naive approach in which the attack period is predetermined and does not change as a result of actual conditions on the grid. In this iteration of the attack, we assume the utility will utilize load shedding when the frequency drops below preset thresholds. The threshold that is violated in the attack is the 59.3 Hz threshold, after which the utility will immediately disconnect 5% of the total load in order to compensate for the fast dropping frequency [63]. This utility behavior is depicted in Figure 12(b) by the squares at time t = 17.9s and t = 33s. The behavior depicted in Figure 12(b) is a response to a more advanced oscillatory load attack requiring the attacker to know and observe the actual grid response to tune the attack load and period. The attacker and utility interaction at every step is summarized in Table 3. Another important aspect of such an attack is the attackers' ability to cause devastating impacts on the grid and very large-frequency deviation with only a small portion of the load required in all of the previous attack scenarios. As a comparison, this oscillatory load attack was able to force the grid to shed part of its load and eventually reach a frequency of 62.8 Hz using 20 MW compared to the 61 Hz frequency reached after the 40 MW drop in load attack.

An extension of the oscillatory load attack can be achieved by utilizing the reverse power discharge through the V2G functionality similar to work performed in [64]. By initiating this V2G at the instance we stop the mass charging, the attacker can cause a larger-frequency spike. It is worth mentioning that by instilling V2G capabilities in mobile applications, the adversary can then utilize it to increase the oscillatory attack effect on the grid.

6 MITIGATION AND RECOMMENDED COUNTERMEASURES

The following section provides recommendations for hardening the EVCS ecosystem by reducing the attack surface and addressing the discovered vulnerabilities. First, we provide suggestions

Table 3. Attack Scenario Description and Impact

#	Time(s)	System State	Action	Action By	Impact (State Change)
1	15	System is operating normally	Total attack load of 40 MW initiated	Attacker	System frequency starts dropping
2	17.9	Frequency drops below 59.3	5% load shedding	Utility	5% of total consumers lose electricity. System frequency starts rising
3	25	The frequency peaks and is regulated by the automatic generator control	Turning off all compromised charging sessions	Attacker	System frequency spikes
4	27.5	The frequency starts dropping due to the automatic generation control	Automatic action of generation control system, "no human intervention"	Automatic	System frequency is being reduced to stabilize the system
5	32	The frequency was reduced by the automatic generation control	Total attack load of 80 MW initiated	Attacker	System frequency starts dropping faster than step 1 due to the larger attack load and the reduced generation after load shedding
6	33	Frequency drops below 59.3	5% load shedding	Utility	Additional 5% of total consumers lose electricity (10% total). System frequency starts rising
7	37	The frequency peaks and is regulated by the automatic generator control	Turning off all compromised charging sessions	Attacker	Causes a larger spike in frequency than step 3 since the EV load that was turned off is larger than that of step 3
8	39.4	Frequency exceeds 61.8 Hz [63]	Generators should be tripped instantaneously	Utility	Sequential generator tripping until system frequency stabilizes
>8	>39.4	Utility trips generators immediately. The system inertia drops	The attack impact is larger, causing more tripping	Attacker	As more generators are tripped, the system reaches a state of blackout

based on industry best practices for securing mobile applications. We then provide suggestions based on the unique properties found in the EV ecosystem.

To assist in mitigating automated attacks, mobile platforms should try to detect bot behavior. To keep malicious software from engaging in abusive behaviors, charging platforms should utilize reCAPTCHA [65] or other similar services that use an advanced risk analysis engine and adaptive challenges. The implementation of reCAPTCHA helps in detecting automated scraping, the creation of synthetic compromised accounts, and automated behaviors. This will not only hinder the attacker from performing the attack but also hinder the attacker from utilizing mobile applications to perform reconnaissance on the EVCSs and their behavior, which is an integral step in preparation for a wide-scale attack against the grid.

While this could hinder the attacker, it does not prevent the adversary from utilizing the lack of end-to-end authentication. Thus, to mitigate the consequences of such vulnerability, we recommend implementing a mechanism for verifying user ownership over the EV. Users should be coupled with their EVs from the beginning, making them the central authority that controls any action performed on their specific EV. Using this, we would add security by design in the interactions between the entities in the EV ecosystem [66]. Each EV has a unique **Vehicle Identification Number (VIN)** that can be used to identify during the creation of the mobile application account in order to verify that this mobile application user actually has a physical EV. The mobile application should later ask the users to enter the VIN of their EV when they attempt to initiate a charging session. This will ensure that only authorized EVs are charged. This allows the creation of a one-one relationship between the vehicle and the owner. This would require collaboration between different counterparts such as charging station vendors and vehicle manufacturers.

To ensure that the decision-making is distributed and more robust against cyber tampering, we recommend that the EVCS needs to check if a connected vehicle has the same VIN as the one that sent in the charging request. If the identifiers match, then the EVCS will start charging after verifying the end-to-end authentication. If no match was found, then it will return an error to the user. The adversary can no longer register to the platform without registering with a valid VIN. Furthermore, even if the adversary creates an account using a legitimate VIN, the adversary will not be able to know the specific VIN of the EV connected at the targeted EVCS. Thus, by enabling a strict end-to-end authentication, the attacker cannot be associated with someone else's EV. This

would prevent the adversary from launching large-scale attacks against the grid. Additionally, EV charging can be restricted to users who are in the vicinity of their EVs and the EVCS. Some EVs have NFC chips installed that can be used to initiate charging. The mobile application can use NFC to communicate with the EV and verify that the user is in close proximity to their EV. The mobile application can use GPS-based location information to confirm that the user is in proximity to the EVCS. This will ensure that only authorized users who are physically present near the EV and EVCS can initiate charging. We understand that such restrictions might affect the usability and commercialization of the mobile application. For example, when Alice lends her car to her son, he should be allowed to charge the EV. Thus, we suggest creating an authorization list where Alice can add a list of verified mobile application accounts that are authorized to control the charging of the EV. By implementing the suggested mitigation methods, the security of the EV charging mobile application will be hardened and the attacks discussed above will be rendered extremely difficult to perform.

7 CONCLUSION

In this work, we explored the security of the EV charging ecosystem by focusing on the understudied EV charging mobile application as a main attack surface. We studied the interactions of the mobile application with other components to understand its remote control functionality over the charging stations. Our analysis of the identified interactions and communications unveiled critical vulnerabilities that allow remote adversaries to gain control over the charging operations and perform DDoS attacks by preventing legitimate users from using the charging equipment. Moreover, while we demonstrate the feasibility of exploiting existing EV charging mobile applications' vulnerabilities to hijack charging sessions, we discuss the implications of such attacks on various stakeholders within the EV charging ecosystem. Specifically, we discuss the impact of wide-scale remote attacks on the underlying critical infrastructure (i.e., the power grid) and show that an attacker can utilize a botnet of adversarial accounts on those vulnerable mobile applications to cripple the operations of the power grid. Finally, while we discuss attack implications against EV consumers, we also recommend countermeasures to secure the infrastructure and impede adversaries from performing reconnaissance and launching remote attacks using compromised accounts. In future work, we aim at studying different distributed blockchain solutions to mitigate these design flaws while minimizing integration overhead for the operators.

REFERENCES

[1] Helen Regan. 2020. China pledges to go carbon neutral by 2060. https://www.cnn.com/2020/09/22/china/xi-jinping-carbon-neutral-2060-intl-hnk/index.html

[2] Linda Gyulai. 2020. Montreal's climate plan includes ban on non-electric cars downtown by 2030. https://montrealgazette.com/news/local-news/montreal-releases-climate-plan-including-ban-on-non-electric-cars-downtown-by-2030

[3] Charles Riley. 2021. Europe aims to kill gasoline and diesel cars by 2035. https://edition.cnn.com/2021/07/14/business/eu-emissions-climate-cars/index.html

[4] Natural Resources Canada. 2021. Government of Canada. https://www.nrcan.gc.ca/energy-efficiency/transportation-alternative-fuels/zero-emission-vehicle-infrastructure-program/21876

[5] Samrat Acharya, Yury Dvorkin, Hrvoje Pandžić, and Ramesh Karri. 2020. Cybersecurity of smart electric vehicle charging: A power grid perspective. *IEEE Access* 8 (2020), 214434–214453.

[6] Mohammad Ali Sayed, Ribal Atallah, Chadi Assi, and Mourad Debbabi. 2021. Electric vehicle attack impact on power grid operation. *International Journal of Electrical Power & Energy Systems* 112 (2021), 107784. DOI: http://dx.doi.org/10.1016/j.ijepes.2021.107784

[7] Tony Nasr, Sadegh Torabi, Elias Bou-Harb, Claude Fachkha, and Chadi Assi. 2021. Power jacking your station: In-depth security analysis of electric vehicle charging station management systems. *Computers & Security* (2021), 102511.

[8] R. Akhras, W. El-Hajj, M. Majdalani, H. Hajj, R. Jabr, and K. Shaban. 2020. Securing smart grid communication using ethereum smart contracts. *International Wireless Communications and Mobile Computing (IWCMC'20)*. Limassol, Cyprus, 1672–1678. DOI: 10.1109/IWCMC48107.2020.9148345

[9] Cristina Alcaraz, Javier Lopez, and Stephen Wolthusen. 2017. OCPP protocol: Security threats and challenges. *IEEE Transactions on Smart Grid* 8, 5 (2017), 2452–2459.
[10] Juan E. Rubio, Cristina Alcaraz, and Javier Lopez. 2018. Addressing security in OCPP: Protection against man-in-the-middle attacks. In *2018 9th IFIP International Conference on New Technologies, Mobility and Security (NTMS'18)*. IEEE, 1–5.
[11] Hossam ElHussini, Chadi Assi, Bassam Moussa, Ribal Atallah, and Ali Ghrayeb. 2021. A tale of two entities: Contextualizing the security of electric vehicle charging stations on the power grid. *ACM Transactions on Internet of Things* 2, 2 (2021), 1–21.
[12] Joseph Antoun, Mohammad Ekramul Kabir, Bassam Moussa, Ribal Atallah, and Chadi Assi. 2020. A detailed security assessment of the EV charging ecosystem. *IEEE Network* 34, 3 (2020), 200–207.
[13] Open Charge Alliance. 2021. OCPP 2.0.1, protocols, home. https://www.openchargealliance.org/protocols/ocpp-201/
[14] Richard Baker and Ivan Martinovic. 2019. Losing the car keys: Wireless phy-layer insecurity in EV charging. In *28th USENIX Security Symposium (USENIX Security'19)*. 407–424.
[15] Y. S. Wong, K. T. Chau, and C. C. Chan. 2006. Battery sizing for plug-in hybrid electric vehicles. *Journal of Asian Electric Vehicles* 4, 2 (2006), 899–904.
[16] Kaspersky Lab. 2021. How do fuel cell electric vehicles work Using hydrogen? https://afdc.energy.gov/vehicles/how-do-fuel-cell-electric-cars-work
[17] Sklyar Dmitry. 2018. ChargePoint Home Security Research. https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2018/12/13084354/ChargePoint-Home-security-research_final.pdf
[18] Juan E. Rubio, Cristina Alcaraz, and Javier Lopez. 2018. Addressing security in OCPP: Protection against man-in-the-middle attacks. In *2018 9th IFIP International Conference on New Technologies, Mobility and Security*. 1–5.
[19] Omniyah Gul M. Khan, Ehab El-Saadany, Amr Youssef, and Mostafa Shaaban. 2019. Impact of electric vehicles botnets on the power grid. In *2019 IEEE Electrical Power and Energy Conference (EPEC'19)*. IEEE, 1–5.
[20] Kristien Clement-Nyns, Edwin Haesen, and Johan Driesen. 2009. The impact of charging plug-in hybrid electric vehicles on a residential distribution grid. *IEEE Transactions on Power Systems* 25, 1 (2009), 371–380.
[21] Niels Leemput, Frederik Geth, Juan Van Roy, Annelies Delnooz, Jeroen Büscher, and Johan Driesen. 2014. Impact of electric vehicle on-board single-phase charging strategies on a flemish residential grid. *IEEE Transactions on Smart Grid* 5, 4 (2014), 1815–1822.
[22] Anamika Dubey and Surya Santoso. 2015. Electric vehicle charging on residential distribution systems: Impacts and mitigations. *IEEE Access* 3 (2015), 1871–1893.
[23] Hugo Morais, Tiago Sousa, Zita Vale, and Pedro Faria. 2014. Evaluation of the electric vehicle impact in the power demand curve in a smart grid environment. *Energy Conversion and Management* 82 (2014), 268–282.
[24] Soroush Shafiee, Mahmud Fotuhi-Firuzabad, and Mohammad Rastegar. 2013. Investigating the impacts of plug-in hybrid electric vehicles on power distribution systems. *IEEE Transactions on Smart Grid* 4, 3 (2013), 1351–1360.
[25] Elif Ustundag Soykan, Mustafa Bagriyanik, and Gurkan Soykan. 2021. Disrupting the power grid via EV charging: The impact of the SMS Phishing attacks. *Sustainable Energy, Grids and Networks* 26 (2021), 100477.
[26] Wei Zhou, Yan Jia, Yao Yao, Lipeng Zhu, Le Guan, Yuhang Mao, Peng Liu, and Yuqing Zhang. 2019. Discovering and understanding the security hazards in the interactions between IoT devices, mobile apps, and clouds on smart home platforms. In *28th USENIX Security Symposium (USENIX Security'19)*. 1133–1150.
[27] S. O'Dea. 2021. Mobile OS market share 2021. https://www.statista.com/statistics/272698/global-market-share-held-by-mobile-operating-systems-since-2009/
[28] 2021. apktool - a tool for reverse engineering 3rd party, closed, binary android apps. https://ibotpeaches.github.io/Apktool/
[29] KALI. 2021. Dex2jar: Kali linux tools. https://www.kali.org/tools/dex2jar/
[30] KALI. 2021. JD-Gui: Kali linux tools. https://www.kali.org/tools/jd-gui/
[31] MobSF. 2021. Mobile security framework (mobsf). https://github.com/MobSF/Mobile-Security-Framework-MobSF
[32] Pkumza. 2021. pkumza/LiteRadar: Lite version of LibRadar. https://github.com/pkumza/LiteRadar
[33] Shengqian Yang, Dacong Yan, Haowei Wu, Yan Wang, and Atanas Rountev. 2015. Static control-flow analysis of user-driven callbacks in Android applications. In *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, Vol. 1. IEEE, 89–99.
[34] Tanzirul Azim and Iulian Neamtiu. 2013. Targeted and depth-first exploration for systematic testing of Android apps. In *Proceedings of the 2013 ACM SIGPLAN International Conference on Object Oriented Programming Systems Languages & Applications*. 641–660.
[35] GPS Joystick Guide-the app ninjas. n. d. http://gpsjoystick.theappninjas.com/
[36] SHIVAM says. 2021. Virtualxposed APK 0.20.3 download latest in 2021 [official]. https://virtualxposed.com/
[37] Ac-Pm. n.d. AC-PM/inspeckage: Android Package Inspector - Dynamic Analysis with API hooks, start unexported activities and more. (Xposed module). https://github.com/ac-pm/Inspeckage

[38] Jens Schmutzler, Claus Amtrup Andersen, and Christian Wietfeld. 2021. Burp Suite - Application Security Testing Software. https://portswigger.net/burp
[39] Jens Schmutzler, Claus Amtrup Andersen, and Christian Wietfeld. 2013. Evaluation of OCPP and IEC 61850 for smart charging electric vehicles. *World Electric Vehicle Journal* 6, 4 (2013), 863–874.
[40] Jens Schmutzler, Christian Wietfeld, and Claus Amtrup Andersen. 2012. Distributed energy resource management for electric vehicles using IEC 61850 and ISO/IEC 15118. In *2012 IEEE Vehicle Power and Propulsion Conference*. IEEE, 1457–1462.
[41] Communication apis for SMS, Voice, Video & Authentication. [n. d.] https://www.twilio.com/
[42] Yu-Wei Chung, Behnam Khaki, Tianyi Li, Chicheng Chu, and Rajit Gadh. 2019. Ensemble machine learning-based algorithm for electric vehicle user behavior prediction. *Applied Energy* 254 (2019), 113732.
[43] Ahmad Almaghrebi, Subhaditya Shom, Fares Al Juheshi, Kevin James, and Mahmoud Alahmad. 2019. Analysis of user charging behavior at public charging stations. In *2019 IEEE Transportation Electrification Conference and Expo (ITEC'19)*. IEEE, 1–6.
[44] Tai-Yu Ma and Sébastien Faye. 2022. Multistep electric vehicle charging station occupancy prediction using hybrid LSTM neural networks. *Energy* vol 244, part B (2022), 123217.
[45] Zachary J. Lee, Tongxin Li, and Steven H. Low. 2019. ACN-data: Analysis and applications of an open EV charging dataset. In *Proceedings of the 10th ACM International Conference on Future Energy Systems*. 139–149.
[46] Appium. 2021. Automation for Apps. https://appium.io/
[47] Saleh Soltan, Prateek Mittal, and H. Vincent Poor. 2018. BlackIoT: IoT botnet of high wattage devices can disrupt the power grid. In *27th USENIX Security Symposium (USENIX Security'18)*. 15–32.
[48] K. Sarieddine, M. A. Sayed, D. Jafarigiv, R. Atallah, M. Debbabi, and C. Assi. 2023. A real-time cosimulation testbed for electric vehicle charging and smart grid security. In *IEEE Security & Privacy* 21, 4 (2023), 74–83. DOI: 10.1109/MSEC.2023.3247374
[49] Yosra Fraiji, Lamia Ben Azzouz, Wassim Trojet, and Leila Azouz Saidane. 2018. Cyber security issues of Internet of electric vehicles. In *2018 IEEE Wireless Communications and Networking Conference (WCNC'18)*. IEEE, 1–6.
[50] Richard M. Pratt and Thomas E. Carroll. 2019. Vehicle charging infrastructure security. In *2019 IEEE International Conference on Consumer Electronics (ICCE'19)*. IEEE, 1–5.
[51] California ISO. 2021. Demand Trend. https://www.caiso.com/TodaysOutlook/Pages/default.aspx
[52] Australian Energy Market Operator (AEMOO). 2021. Demand Trend. https://aemo.com.au/en
[53] Guido Cavraro, Andrey Bernstein, Vassilis Kekatos, and Yingchen Zhang. 2019. Real-time identifiability of power distribution network topologies with limited monitoring. *IEEE Control Systems Letters* 4, 2 (2019), 325–330.
[54] Seyed Iman Taheri, M. B. C. Salles, and N. Kagan. 2019. A new modified TLBO algorithm for placement of AVRs in distribution system. In *2019 IEEE PES Innovative Smart Grid Technologies Conference-Latin America*. IEEE, 1–6.
[55] Guido Cavraro and Vassilis Kekatos. 2019. Inverter probing for power distribution network topology processing. *IEEE Transactions on Control of Network Systems* 6, 3 (2019), 980–992.
[56] Keith Moffat, Mohini Bariya, and Alexandra Von Meier. 2019. Unsupervised impedance and topology estimation of distribution networks—limitations and tools. *IEEE Transactions on Smart Grid* 11, 1 (2019), 846–856.
[57] Anandini Gandluru, Shiva Poudel, and Anamika Dubey. 2019. Joint estimation of operational topology and outages for unbalanced power distribution systems. *IEEE Transactions on Power Systems* 35, 1 (2019), 605–617.
[58] Deepjyoti Deka, Michael Chertkov, and Scott Backhaus. 2019. Topology estimation using graphical models in multi-phase power distribution grids. *IEEE Transactions on Power Systems* 35, 3 (2019), 1663–1673.
[59] Keith Moffat, Mohini Bariya, and Alexandra Von Meier. 2020. Real time effective impedance estimation for power system state estimation. In *2020 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT'20)*. IEEE, 1–5.
[60] Prabha Kundur. 2007. Power system stability. *Power System Stability and Control*, (3rd edition), (2007), 7–1.
[61] J. Duncan Glover, Mulukutla S. Sarma, and Thomas Overbye. 2012. *Power System Analysis & Design, SI Version*. Cengage Learning.
[62] PowerWorld. 2021. https://www.powerworld.com/
[63] Bing Huang, Alvaro A. Cardenas, and Ross Baldick. 2019. Not everything is dark and gloomy: Power grid protections against IoT demand attacks. In *28th USENIX Security Symposium (USENIX Security'19)*. 1115–1132.
[64] M. E. Kabir, M. Ghafouri, B. Moussa, and C. Assi. 2021. A two-stage protection method for detection and mitigation of coordinated EVSE switching attacks. In *IEEE Transactions on Smart Grid* 12, 5 (2021), 4377–4388. DOI: 10.1109/TSG.2021.3083696
[65] ReCAPTCHA. 2021. https://www.google.com/recaptcha/about/
[66] Smartcar Âů API platform for Connected Car Data. n.d. https://smartcar.com/

Received 26 February 2023; revised 24 May 2023; accepted 1 July 2023